Informe Laboratorio 3

Sección 4

Francisco Antonio Tapia Canales
e-mail: francisco.tapia1@mail.udp.cl

Criptografía y Seguridad en Redes CIT2113
Profesor Brayan Espina
Octubre de 2026

Índice

1. Descripción de actividades **2**

2. Desarrollo **3**

2.1. Hash en el registro 3

2.2. Hash en el inicio de sesión 3

2.3. Generación del hash en la consola 4

2.4. Interceptación con Burp Suite 4

2.5. Inicio de sesión mediante el hash 5

2.6. Privacidad y seguridad 7

2.7. Conclusiones sobre la seguridad 8

1. Descripción de actividades

El objetivo de este laboratorio fue auditar la transformación de contraseñas en páginas web desde el lado del cliente y evaluar la reutilización de un hash para iniciar sesión, mediante una prueba de Pass the Hash.

Se seleccionó https://www.forodvd.com/ y se creó una cuenta de prueba perteneciente al estudiante, con una contraseña destinada a esta actividad. Se trabajó con Ubuntu en VMware Workstation y con el navegador integrado de Burp Suite Community.

Se realizaron las siguientes actividades:

• Se identificó el algoritmo hash utilizado al registrar la cuenta.

• Se compararon los parámetros enviados durante el inicio de sesión.

• Se calculó el hash de la contraseña desde la consola del navegador.

• Se detuvo una solicitud de login en Proxy Intercept de Burp Suite.

• Se comprobó el rechazo de una contraseña incorrecta y se repitió el acceso sustituyendo sus hashes por el valor correcto.

• Se revisaron la política de privacidad enlazada por el sitio y los controles observados en la interfaz.

• Se elaboraron cuatro conclusiones sobre los resultados y su alcance.

La práctica mostró que el registro y el login enviaron MD5 en el cliente. La contraseña incorrecta fue rechazada, mientras que la solicitud con el hash correcto reutilizado abrió una sesión. La cuenta mantuvo pendiente la activación por correo para participar en el foro.

Al concluir, se envió un cambio de contraseña y se conservó la confirmación de actualización del perfil. La contraseña nueva no forma parte de las evidencias.

2. Desarrollo

2.1. Hash en el registro

Después de registrar la cuenta, se identificó en Burp la solicitud POST a /register.php?do=addmember. Los parámetros password_md5 y passwordconfirm_md5 contenían el mismo valor. Los campos password y passwordconfirm aparecían vacíos.

```
password_md5 = 95e5ffce381c006ca63266ecc0ac6771
passwordconfirm_md5 = 95e5ffce381c006ca63266ecc0ac6771
```

Se identificó MD5 mediante la biblioteca pública vbulletin_md5.js y la coincidencia con hex_md5 al ingresar la misma contraseña en la consola. El tamaño de 32 caracteres hexadecimales es compatible con MD5, pero la identificación también se apoyó en el código y en esa comparación.



Figura 1. Campos password_md5 y passwordconfirm_md5 del registro.

2.2. Hash en el inicio de sesión

La solicitud POST a /login.php?do=login envió el mismo valor en vb_login_md5password y vb_login_md5password_utf. El parámetro vb_login_password quedó vacío. Para la contraseña utilizada, los dos campos coincidieron con el registro y con la consola.

El formulario público ejecuta md5hash al enviarse y carga la biblioteca que define hex_md5. Esto permite ubicar la transformación en el navegador. Las capturas describen el valor enviado por el cliente; el almacenamiento interno del servidor no se observó.

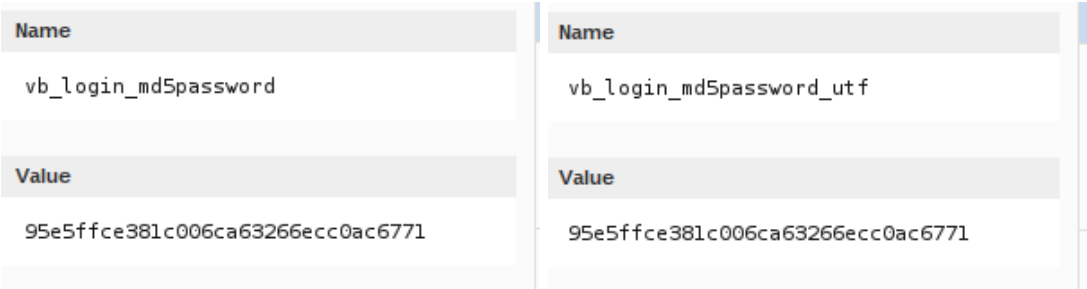


Figura 2. Ambos campos de login contienen el mismo MD5 que el registro.

2.3. Generación del hash en la consola

En la consola del navegador de ForoDVD se ejecutó la función disponible en la página. La contraseña de prueba se introdujo en el cuadro de diálogo generado por prompt.

```
hex_md5(prompt("Introduce la contraseña que usaste al registrarte"))
```

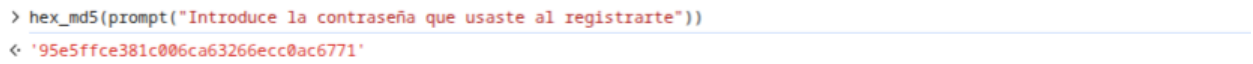


Figura 3. Recorte de la captura original con el comando correcto y su resultado.

El resultado fue 95e5ffce381c006ca63266ecc0ac6771. Coincidió con password_md5 del registro y con los dos parámetros MD5 del login. La contraseña se ingresó en el cuadro de diálogo de prompt; la función hex_md5 ya estaba cargada por ForoDVD.

2.4. Interceptación con Burp Suite

En Burp se abrió Proxy, se utilizó Open browser y se navegó hasta el formulario de acceso. Se activó Intercept antes de pulsar Iniciar sesión y se seleccionó la petición POST a /login.php?do=login. La figura 4 muestra Intercept on y la solicitud detenida.

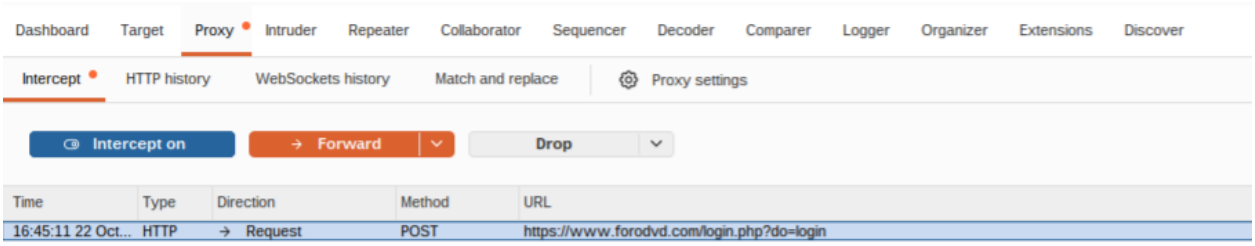


Figura 4. Petición POST de login detenida en Proxy Intercept.

Los campos se revisaron en Inspector y después en Raw. En la captura de la figura 5, correspondiente al intento con contraseña incorrecta, vb_login_md5password contenía el valor indicado. Ambos campos se modificaron en el punto 2.5.

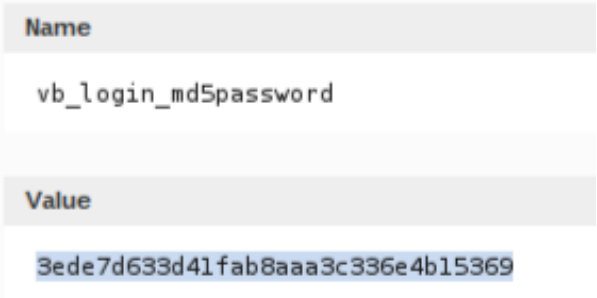


Figura 5. Hash de la contraseña incorrecta observado en la solicitud detenida.

La captura se realizó desde el navegador configurado con Burp. Este resultado acredita la inspección de esa sesión, sin demostrar una interceptación de HTTPS desde un equipo ajeno al navegador de prueba.

2.5. Inicio de sesión mediante el hash

Primero se comprobó el acceso normal y se cerró la sesión. Después se envió una contraseña incorrecta, sin sustituir sus hashes, para observar el comportamiento de rechazo.

El hash correcto se había observado en los campos del login capturado en Burp (figura 2) y se comprobó con la consola (figura 3).

Prueba	Credencial enviada	Resultado
A Control correcto	Hash generado a partir de la contraseña correcta.	Sesión iniciada.
B Control incorrecto	Hash generado a partir de una contraseña incorrecta.	Acceso rechazado.
C Sustitución	Contraseña incorrecta en el formulario y ambos hashes reemplazados por el correcto.	Sesión iniciada.

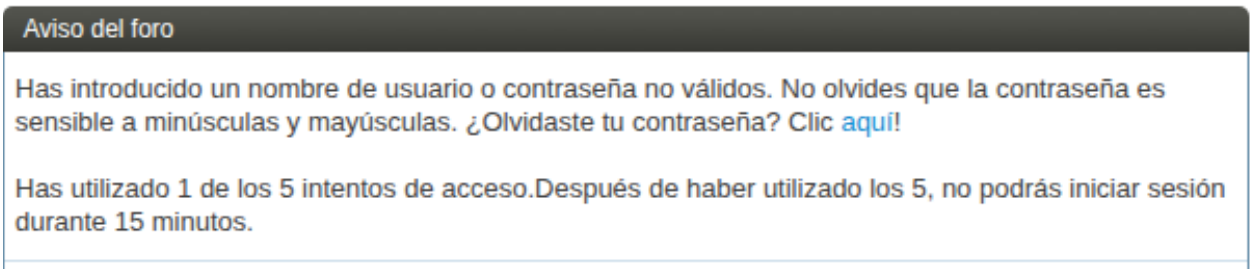


Figura 6. Rechazo del acceso con contraseña incorrecta antes de sustituir el hash.

El sitio informó un intento utilizado de cinco e indicó un bloqueo de 15 minutos al agotar ese límite. La captura acredita el aviso; no se agotaron los intentos para comprobar el bloqueo.

Se repitió el ingreso con una contraseña incorrecta y se activó Intercept antes de enviar. Ambos parámetros contenían el hash incorrecto indicado abajo. En Raw se sustituyeron únicamente esos dos valores por el hash correcto, conservando los demás datos de la solicitud vigente.

```
Hash incorrecto observado:
3ede7d633d41fab8aaa3c336e4b15369

Hash correcto reutilizado:
95e5ffce381c006ca63266ecc0ac6771
```

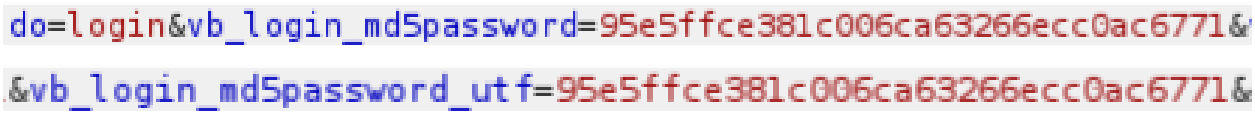


Figura 7. Dos recortes de la misma línea de la solicitud con los hashes sustituidos.

Se sustituyeron vb_login_md5password y vb_login_md5password_utf por el MD5 correcto, sin cambiar el resto de la solicitud vigente. Después se pulsó Forward y se dejó Intercept off para que terminara la navegación.

Resultado de la prueba

Antes de la sustitución se había comprobado el acceso normal con la contraseña correcta y esa sesión se había cerrado para realizar el control incorrecto.

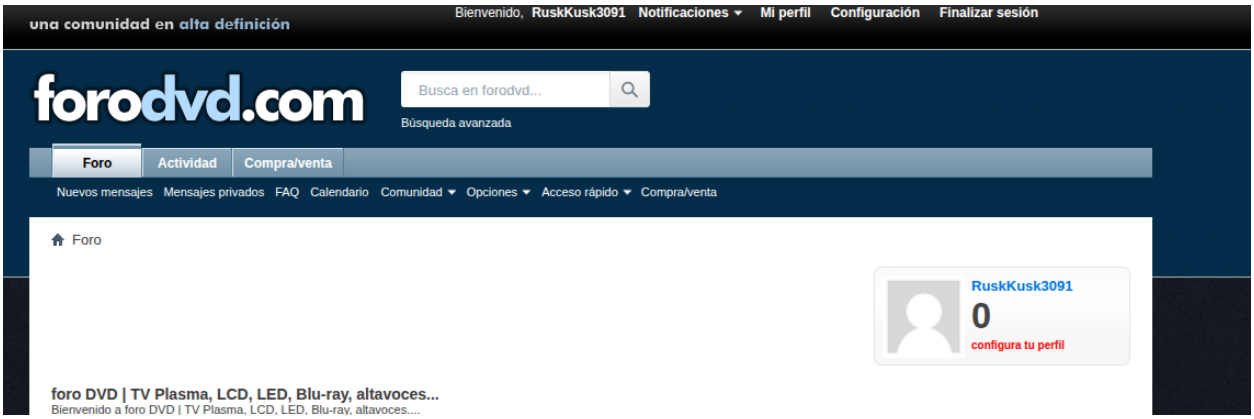


Figura 8. Control previo de acceso con la contraseña correcta.

Después de pulsar Forward y desactivar Intercept, ForoDVD mostró el usuario de prueba y la opción Finalizar sesión. La captura siguiente corresponde al resultado de esa solicitud modificada.

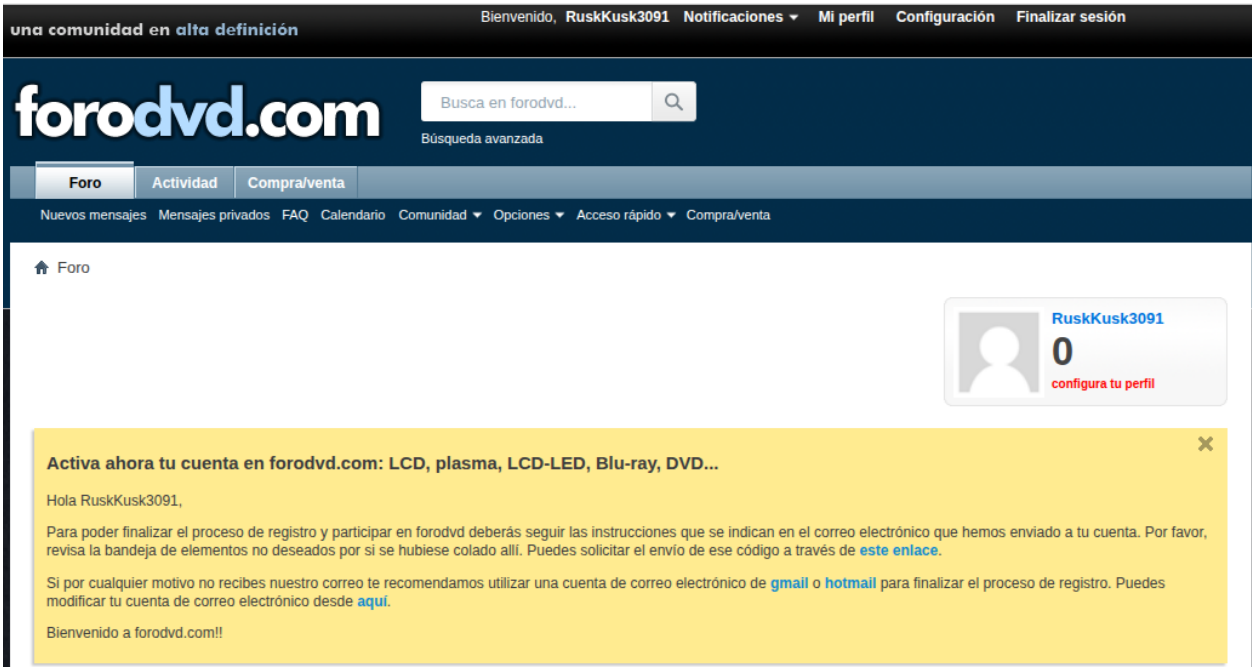


Figura 9. Sesión iniciada después de enviar la solicitud con los hashes sustituidos.

El resultado demuestra que, en la cuenta de prueba del estudiante, el hash capturado fue suficiente para autenticar el acceso al incorporarlo a una solicitud válida. La contraseña escrita inicialmente en el formulario era incorrecta. Se reutilizó el hash como credencial; no fue necesario recuperar la contraseña a partir de ese valor.

La cuenta continuó pendiente de activación por correo para participar en el foro. Ese aviso limita la participación y no impidió que el sitio abriera una sesión autenticada.

2.6. Privacidad y seguridad

El enlace Privacidad del pie de ForoDVD dirige a la política de protección de datos de HD Bits. Ese documento se revisó como política publicada por el operador del sitio.

Contenido de la política publicada

La política identifica a HD Bits Networks SL como responsable del tratamiento. Declara confidencialidad de los datos y reconoce derechos de acceso, rectificación, cancelación y oposición. Indica que una cesión de datos a terceros requeriría informar al usuario y solicitar su consentimiento. También describe comunicaciones comerciales voluntarias y la gestión de preferencias desde el perfil del foro.

La política declara: «Sus datos serán tratados con absoluta confidencialidad».

El texto revisado no detalla el algoritmo usado para las contraseñas, sal, iteraciones, almacenamiento, longitud mínima ni autenticación de varios factores. Por ello, la política aporta compromisos generales sobre datos personales, pero no permite determinar cómo se protegen las contraseñas en el servidor.

Enlace a la política:
https://www.hdbits.es/politica-de-proteccion-de-datos/

Controles observados en las pantallas

Control	**Evidencia y alcance**
Contraseña incorrecta	El sitio rechazó el intento sin sustituir el hash.
Límite anunciado	Aviso de cinco intentos y bloqueo de 15 minutos; no se agotó el límite.
Activación de cuenta	La página pidió activación por correo para participar, aunque permitió iniciar sesión.
Cambio de contraseña	El formulario pidió contraseña actual, nueva y confirmación.
Mayúsculas y minúsculas	La interfaz indicó que las contraseñas distinguen mayúsculas y minúsculas.

Los controles de esta tabla se identificaron en la ejecución práctica. Se distinguen de las declaraciones de la política para no atribuir al documento detalles que no publica.

2.7. Conclusiones sobre la seguridad

1. El cliente envía un hash que se mantiene estable

Para la contraseña de prueba, el registro, la consola y los dos campos del login produjeron el mismo MD5. El cálculo observado no incorporó un reto variable al valor enviado. Esto permitió identificar una credencial derivada estable en las operaciones analizadas.

2. El hash capturado permitió autenticar el acceso

El acceso con contraseña incorrecta fue rechazado. Al repetir el intento y reemplazar ambos hashes por el valor correcto, el sitio abrió una sesión. Por tanto, quien dispusiera de ese valor y de una solicitud válida podría intentar usarlo como credencial en el contexto probado. El experimento permitió comprobar la reutilización del hash como credencial en el flujo analizado.

3. Los controles adicionales tienen funciones diferentes

El sitio validó el valor recibido y anunció límites para intentos fallidos. También mantuvo la activación por correo pendiente para participar. En la prueba, estos controles coexistieron con la aceptación del hash correcto reutilizado. El límite de intentos no se evaluó hasta el bloqueo y la activación no se eludió.

4. El análisis del cliente tiene un alcance concreto

Observar MD5 en el navegador y reutilizar ese valor no permite conocer cómo el servidor guarda las contraseñas. La política revisada tampoco publica esos detalles. La conclusión comprobada se limita a la aceptación del hash como credencial en esta cuenta y este flujo. Una evaluación del almacenamiento o de otras cuentas requeriría evidencia adicional.

Conclusiones y comentarios

El hash enviado por el cliente debe protegerse como una credencial cuando su posesión permite iniciar sesión. La práctica comprobó este comportamiento mediante el rechazo del control incorrecto, la sustitución de ambos hashes y el acceso posterior con la cuenta propia.

En Configuración se abrió Editar correo y contraseña, se completaron los campos de contraseña actual, nueva y confirmación, y se seleccionó Guardar cambios. El sitio confirmó la actualización del perfil. No se volvió a probar el hash antiguo después del cambio.

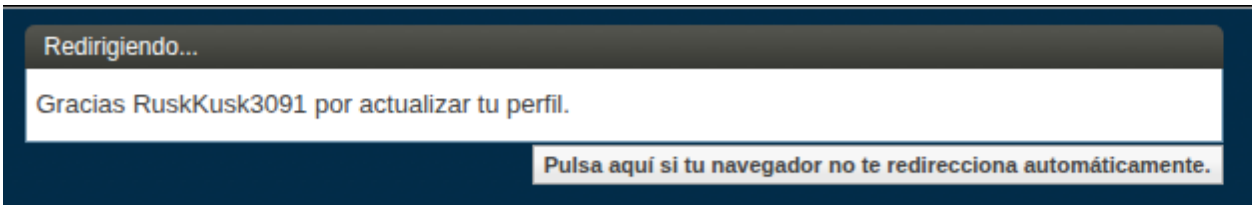


Figura 10. Confirmación de actualización después de enviar el cambio de contraseña.

Repositorio Git: https://github.com/rkkas/laboratorio3-forodvd